CS205 Quiz 4 File by Tanveer Online Academy

Under the continual improvement cycle proposed in this module, corrective actions are taken by.	**All it users in the organization**
Which of the following statements are true?	**Principles of risk management and frameworks are closely related**
Guidelines should be:	**Complied in letter and spirit**
Standards are:	**Required by regulators**
An information security policy can best be described as:	**Formal statements produced and supported by senior management, reflecting objectives for the**

	information security program
Which of the following come at the center of risk management process?	**Risk assessment and risk treatment**
With how many time sources the clocks of all relevant information processing systems should be synchronized to record events and generate evidence?	**At least three time sources**
Which of the following activity should be performed to test organizational readiness to identify and stop attacks or to respond quickly and effectively?	**Periodic red team exercise**
In a large-sized security organization in Pakistan, it is likely the number of security staff will be.	**Over 50**
How can an organization ensure protection of assets that are accessible by suppliers?	**By addressing information security requirements within supplier agreement**
What was the old name of iso27002:2013 standard?	**ISO 17799**
The total numbers of discretionary controls in appendix a5 through a18 are:	**121**
The 4-layer security transformation model.	**Is adapted to solve Pakistan's security posture challenges while being practical**

	not to waste time on security governance in the absence of solid underlying security controls
In process review stage of incident management what questions or points should be reviewed?	**What has occurred?**
When a flaw in infrastructure related to services needs to be addressed immediately, this would be a?	**Emergency change**
Which devices are to be maintained in systems inventory?	**Each system connected to organization's public and private network**
At which phase of information systems life cycle information security becomes integral part?	**Entire life cycle**
In process review stage of incident management what questions or points should be reviewed?	**What has occurred?**
In which format results of penetration testing should be documented?	**Machine readable standard**
After getting vulnerability scanning results patches should be applied to?	**All the systems throughout the organization**

If a system in an organization gets compromised, how can we prevent an attacker to compromise the neighboring systems?	**Through network-based intrusion prevention system(ips)**
Boundary defense controls comes under which category of cis critical controls?	**Isolated from organization's primary network**
When a vulnerability scan is run and report is generated and shared with respective resources, which vulnerabilities they should fix on priority basis?	**Critical risk vulnerabilities**
If multi-factor authentication is not supported then user accounts shall be required to?	**Use passwords longer than 14 characters**
Why should we use scap validated vulnerability scanner?	**Because it looks for both code-based and configuration-based vulnerabilities**
In which mode should vulnerability scanning be performed?	**Authenticated mode**
Which cloud storage should be allowed to use in organization as per cis?	**Authorized cloud storage**
Which of the following system configuration management tool is used for Linux systems?	**Puppet**
As per malware defense control why DNS query logging should be enabled?	**To detect host-name lookup for known malicious domains**

Boundary defense controls comes under which category of cis critical controls?	**Basic controls**
Each person with administrator account should be authorized by?	**Senior executive**
What should a system do whenever an administrator account is added or removed?	**Issue a log entry and alert**
How can an authorized wireless access point connected to a wired network can be detected and alerts can be generated?	**Through network-based intrusion detection system**
The dedicated machine used by administrators for administrative tasks should have following features.	**Isolated from organization's primary network**
What should standard secure configuration images represent?	**Hardened versions of underlying OS and application installed on system**
Which policy is recommended by data protection control of cis for mobile devices usage in an organization?	**Hard drive of mobile devices should be encrypted**
As per cis which authentication protocols should be used by wireless networks?	**Which require mutual multi-factor authentication**

As per cis critical security framework what is recommended for network boundaries of an organization?	**Deny communication over unauthorized TCP or UDP ports**
What type of machine should network administrators use for administrative tasks?	**Isolated from organization's primary network**
Before deploying any new devices in a networked environment what should be done with passwords?	**Change the default passwords**
Which of the following cis critical control is discussed in this module?	**Boundary defense**
Which of the following tools can be used to enforce access controls to data?	**Host-based data loss prevention (dlp)**
As per limitation and control of network control of cis active ports, protocols and services should be associated to.	**All the assets in asset inventory**
Why cis recommends to configure monitoring system in an organization's network?	**To detect compromise of systems at organization's network boundaries**
As per boundary defense control of cis what should be done with network traffic at proxy?	**Decrypt all encrypted network traffic prior to analyzing the content**

The main difference between security organization in a large-sized and medium sized organization is that the following is absent in a medium sized security organization.	**Chief risk officer**
In a medium-sized security organization in Pakistan, it is likely the number of security staff will be.	**10-15**
According to this module, the main function of the ciso (in an organization where ciso is reporting to cio) is to conduct the following for the security program.	**Review, monitor, and propose**
As per cis critical controls from how many minimum synchronized time resources all networks devices and servers should retrieve time?	**One**
As per cis framework what is the best practice to store logs generated from system?	**Aggregate logs to a central management system**
Automated configuration monitoring tools should compliant with which protocol to streamline reporting?	**Scap**
From which type of systems URL requests should be logged in order to identify potentially malicious activity?	**Each of the organization's system**
In a large-sized security organization (belonging to a large-sized organization), the following security functions are likely to be found.	**Engineering, operations, governance, and frameworks/standards**

Automated tools should be used to verify and compare the network devices configuration with.	**Approved security configuration**
Security governance may be considered as.	**A parallel function to IT governance**
While implementing the 4-layer security transformation model.	**It is suggested to have a high level and minimal (concise) policy in place**
Which of the following can be used to block malicious traffic on organization's network boundaries?	**Network-based intrusion prevention (ips) system**
Centrally managed anti-malware software should be used in an organization to.	**Continuously monitor and defend organization's servers and workstations**
Generally speaking, security implementation in Pakistan is.	**One generation behind that of it**